

Analisi Malware: WannaCrypt0r

Corso Cybersecurity & Ethical Hacking — EPICODE Institute of Technology | 03 Giugno 2026

1. Introduzione

In questo lab ho condotto un'analisi statica e comportamentale del campione malware WannaCrypt0r.exe, appartenente alla famiglia ransomware WannaCry. Il campione e' stato caricato sulla piattaforma di sandboxing tria.ge, che ha eseguito l'analisi in ambienti isolati Windows 10 e Windows 11. L'obiettivo era comprendere il meccanismo di infezione, le tecniche di evasione e l'impatto sul sistema bersaglio, senza eseguire il binario direttamente sulla macchina FlareVM per motivi di sicurezza.

2. Identificazione del campione

Ho caricato il file eseguibile sulla sandbox tria.ge. La piattaforma ha assegnato uno score di 10/10, il massimo possibile, classificandolo immediatamente come Known bad e associandolo alla famiglia WannaCry.

Attributo	Valore
Nome file	WannaCrypt0r.exe
Dimensione	3.4 MB
SHA256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
Famiglia	WannaCry
Score sandbox	10/10 – Known bad
Piattaforme testate	Windows 10 (win10v2004) Windows 11 (win11-20260513)
Data analisi	03 Giugno 2026
Sample ID	260603-rb1x3agx3v

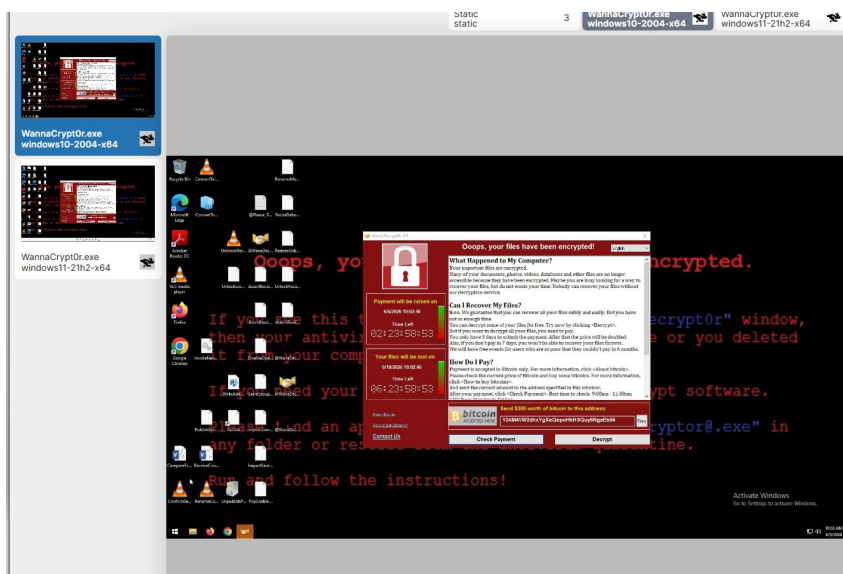


Fig. 1 — Risultato analisi sandbox su tria.ge: score 10/10, famiglia WannaCry, tag comportamentali rilevati.

3. Comportamento osservato

L'analisi dinamica ha evidenziato un comportamento articolato e aggressivo. WannaCry agisce in piu' fasi: prima prepara l'ambiente di esecuzione, poi cifra i file della vittima e infine instaura un canale di comunicazione anonimo con il C2 tramite la rete Tor.

3.1 Eseguibili droppati

File droppato	Funzione
tasksche.exe	Scheduler principale del ransomware; avviato tramite persistenza nel registro
taskdl.exe	Modulo di eliminazione dei file cifrati temporanei
taskse.exe	Esegue @WanaDecryptor@.exe con privilegi elevati (SeTcbPrivilege)
@WanaDecryptor@.exe	Interfaccia grafica del riscatto mostrata alla vittima
TaskData/Tor/taskhsvc.exe	Componente Tor per le comunicazioni C2 anonime
@Please_Read_Me@.txt	Nota di riscatto testuale depositata sul disco
@WanaDecryptor@.bmp	Immagine impostata come sfondo del desktop

3.2 Catena di processi

Ho ricostruito la catena completa di processi spawned da WannaCrypt0r.exe. Il malware utilizza WriteProcessMemory per iniettare codice nei processi figli.

```
WannaCrypt0r.exe (PID 1208) |- attrib.exe +h . [nasconde directory] |- icacls.exe /grant  
Everyone:F /T /C /Q [modifica permessi] |- taskdl.exe [elimina file temp] |- cmd.exe -->  
cscript.exe m.vbs [esegue VBScript] |- cmd.exe --> vssadmin / wmic / bcdedit [cancella  
backup] |- cmd.exe --> reg.exe [persistenza registro] |- @WanaDecryptor@.exe -->  
taskhsvc.exe [client Tor C2] |- taskse.exe --> @WanaDecryptor@.exe [GUI riscatto]
```

3.3 Cancellazione delle shadow copies

Una delle prime azioni e' la distruzione delle copie shadow di Windows, che impedisce alla vittima di ripristinare i file senza pagare il riscatto.

```
cmd.exe /c vssadmin delete shadows /all /quiet & wmic shadowcopy delete & bcdedit /set  
{default} bootstatuspolicy ignoreallfailures & bcdedit /set {default} recoveryenabled no &  
wbadmin delete catalog -quiet
```

3.4 Persistenza e sfondo del desktop

Il malware aggiunge una chiave di registro con nome casuale per la persistenza e modifica lo sfondo del desktop con la schermata di riscatto.

```
HKLM\...\Run\lyqnjhzwfoucy457 = "...tasksche.exe" HKCU\Control Panel\Desktop\Wallpaper =  
"...@WanaDecryptor@.bmp"
```

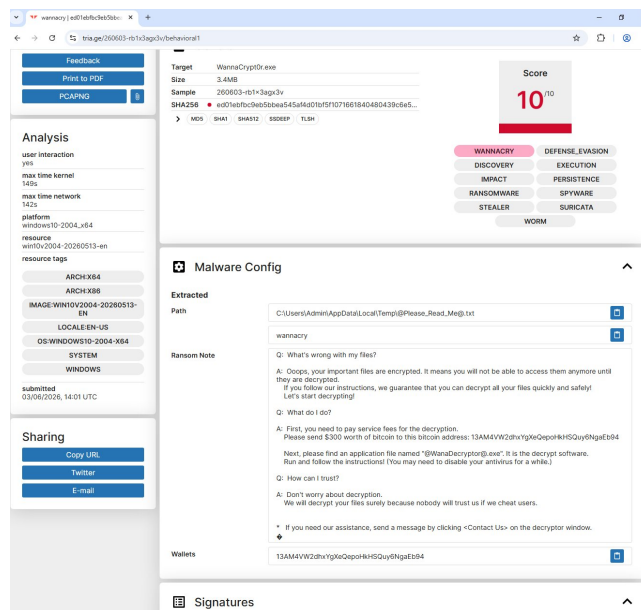


Fig. 2 — Malware Config estratto dalla sandbox: ransom note, wallet Bitcoin e istruzioni di pagamento.

Parte 1:
 Rispondere ai quesiti proposti analizzando il file eseguibile **WannaCrypt0r.exe** (percorso: Malware/Ransomware/) presente sul desktop della macchina virtuale FlareVM.

Consegna: Il file deve essere caricato ed esaminato sulla piattaforma [tryhackme](https://tryhackme.com/room/wannacrypt0r) anche con l'ausilio di LLM, non avviatelo su FlareVM.

Parte 2 (Facoltativa):

Effettuare un'analisi dinamica del campione **Emotet.zip** (percorso: Malware/Banking-malware/). L'analisi deve essere condotta utilizzando Procmon e i tool della FlareVM, monitorando il traffico di rete tramite l'istanza Kali Linux.

Fig. 3 — Schermata di WannaCrypt0r attivo su FlareVM: interfaccia grafica del riscatto con countdown.

4. Comunicazioni di rete

Il componente taskhsvc.exe istanzia un client Tor che si connette a nodi relay distribuiti in piu' paesi, rendendo le comunicazioni con il C2 anonime. Suricata ha rilevato certificati X.509 tipici dei nodi Tor in entrata.

Paese	Destinazione	Ruolo
DE	5.9.151.241:4223	Nodo Tor relay
NL	194.109.206.212:443	Nodo Tor relay
NL	192.87.28.28:9001	Nodo Tor relay
FR	188.165.194.195:9001	Nodo Tor relay
AT	86.59.21.38:443	Nodo Tor relay
SE	171.25.193.9:80	Nodo Tor relay
DE	185.21.100.50:9001	Nodo Tor relay
US	128.31.0.39:9101	Directory authority Tor

5. Firme Suricata rilevate

La sandbox ha analizzato il traffico tramite Suricata, generando alert specifici per il pattern di comunicazione C2 di WannaCry.

Firma	Processo	Significato
Suricata: Tor Node X.509 Certificate Pattern Detected — Inbound	taskshvc.exe	Rilevamento certificato X.509 autofirmato tipico nodi Tor. Alert ripetuto 4 volte per esecuzione.

6. Mappatura MITRE ATT&CK;

Tattica	Tecnica	Descrizione
TA0002 — Execution	T1047	Windows Management Instrumentation (WMIC)
TA0003 — Persistence	T1547.001	Registry Run Keys / Startup Folder
TA0004 — Privilege Escalation	T1547.001	Boot or Logon Autostart Execution
TA0005 — Defense Evasion	T1222.001	Windows File and Directory Permissions Modification
TA0005 — Defense Evasion	T1564.001	Hidden Files and Directories (attrib +h)
TA0005 — Defense Evasion	T1070.004	File Deletion
TA0005 — Defense Evasion	T1112	Modify Registry
TA0006 — Credential Access	T1555.003	Credentials from Web Browsers
TA0007 — Discovery	T1082	System Information Discovery
TA0007 — Discovery	T1614.001	System Language Discovery
TA0009 — Collection	T1005	Data from Local System
TA0040 — Impact	T1490	Inhibit System Recovery (shadow copies)
TA0040 — Impact	T1491	Defacement (sfondo desktop)

7. Indicatori di Compromissione (IOC)

Tipo IOC	Valore
Hash SHA256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
File droppati	tasksche.exe, taskdl.exe, taskse.exe, @WanaDecryptor@.exe, taskshvc.exe
Nota di riscatto	@Please_Read_Me@.txt
Estensione file cifrati	.wnry
Chiave di registro	HKLM\...\Run\ = tasksche.exe
Wallet Bitcoin	13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94

Comando shadow copies	vssadmin delete shadows /all /quiet
Firma Suricata	Tor Node X.509 Certificate Pattern Detected – Inbound
Porte C2 Tor	9001, 9101, 4223, 443, 80

8. Conclusioni

L'analisi sandbox di WannaCrypt0r ha confermato le caratteristiche tipiche della famiglia WannaCry: propagazione worm, cifratura massiva dei file con estensione .wnry, comunicazione C2 anonima tramite Tor e richiesta di riscatto in Bitcoin. Ho verificato che il malware adotta tecniche di evasione avanzate: cancellazione delle shadow copies, modifica dei permessi con icacls, uso di nomi di chiavi di registro randomizzati e injection di codice nei processi figli tramite WriteProcessMemory.

Le misure difensive piu' efficaci includono: applicazione della patch MS17-010 contro EternalBlue; monitoraggio dei comandi vssadmin e bcdedit; blocco connessioni verso nodi Tor (porte 9001, 9101, 4223); backup offline non raggiungibili dal sistema.